Enclave

Perché è diverso da tutti gli altri coding agent — spiegato in modo semplice

Enclave è un assistente AI da riga di comando, open source (licenza MIT), scritto in Rust. A prima vista fa ciò che fanno gli altri: parla con un modello, legge e scrive file, esegue comandi, ricorda le conversazioni. La differenza è il **punto di partenza**: gli altri agent nascono per essere potenti e comodi nel cloud; Enclave nasce con una regola sola davanti a tutte — **i tuoi dati restano tuoi**.

1. Cosa fanno gli altri coding agent (e qual è il problema)

Strumenti come gli agent da terminale, gli assistenti dentro gli editor e i plugin "AI" in genere funzionano così: salvi la cronologia e le chiavi API in file leggibili, spesso in chiaro; tutto ciò che scrivi (codice, segreti, dati dei clienti) viene inviato ai server del fornitore; l'esecuzione di comandi avviene con i tuoi permessi, senza gabbia; e in molti casi sono attivi telemetria, condivisione sessioni e plugin di terze parti. Sono comodissimi, ma la **privacy** è un'aggiunta, non le fondamenta.

2. Cosa cambia con Enclave

Enclave ribalta le priorità. Ecco i punti di forza, uno per uno.

a) Privacy by design (le fondamenta)

- **Tutto cifrato a riposo**: la memoria delle chat è in un database SQLCipher cifrato con AES-256; senza la tua master password è illeggibile.
- **Master password robusta**: la chiave si deriva con Argon2id (memory-hard), la memoria che la contiene è bloccata (*mlock*, non finisce nello swap) e viene azzerata alla chiusura.
- **Zero telemetria, zero cloud**: nessun account, nessun tracciamento, nessuna condivisione. Non esiste un server di Enclave.
- **Chiavi API protette**: variabili d'ambiente o file locale con permessi 0600, non in chiaro nel repository.

b) Controllo su ciò che esce dalla macchina

- **Privacy guard**: prima di inviare, Enclave cerca dati sensibili (email, telefoni, IBAN, carte, segreti, IP) e anche nomi, aziende e indirizzi con un riconoscitore locale. Puoi inviare, sostituire con segnaposto o rifiutare.
- **Taint tracking**: un dato segnalato una volta viene ricordato e ripulito automaticamente nei turni successivi: non "sfugge" più.
- **Policy-as-code**: regole tipo "le email si possono inviare, i numeri di carta no": l'invio viene bloccato o ripulito secondo la tua politica.
- **Air-gap**: una modalità che rifiuta qualsiasi invio verso servizi remoti — lavori solo in locale, offline.
- **Routing locale**: i turni sensibili possono essere dirottati automaticamente su un modello locale (Ollama) invece che al cloud.
- **DLP con giudice locale**: un piccolo modello offline rilegge il contenuto in uscita e ferma le fughe di dati.

c) Sicurezza quando si eseguono comandi

- **Ask-always**: nessun comando parte senza il tuo "sì". Ogni azione è proposta e approvata.
- **Sandbox di sistema**: i comandi approvati girano in una gabbia (su macOS *sandbox-exec*) che limita le scritture all'area di lavoro e, in modalità severa, blocca la rete.
- **Modalità Plan/Build**: "Plan" è in sola lettura (analizza e propone, non modifica); "Build" ha accesso completo ma sempre secondo i tuoi permessi.
- **Permessi granulari**: regole su lettura, scrittura, esecuzione, sottocomandi e cartelle esterne.

d) Difesa dal prompt injection

Il contenuto di file e comandi è trattato come **dato non fidato**, mai come istruzione. Un token "canarino" segreto permette di accorgersi se qualcuno prova a farlo uscire, e qualsiasi azione che nasce da testo non fidato richiede di nuovo la tua approvazione.

e) Trasparenza e verificabilità (la prova, non solo la promessa)

- **Egress ledger**: un registro cifrato di ogni invio (fornitore, modello, orario, impronta del contenuto e mappa delle redazioni) con catena di hash: se qualcuno lo manomette, il controllo di integrità lo rileva.
- **Privacy blast-radius**: mostra quanti dati sono usciti, verso chi, e quali tipi di dati sensibili sono stati toccati.
- **Privacy score**: un voto 0–100 sulla tua postura di privacy, con la spiegazione di ogni punto.
- **Context inspector**: vedi esattamente *cosa* compone la richiesta (prompt, regole, memoria, decisioni) e *quanto pesa*, con un budget di token che ti avvisa quando stai per eccedere.
- **Proof-of-redaction**: la versione originale resta cifrata e verificabile anche dopo aver inviato quella ripulita.

f) Sovranità dei dati

- **Memoria locale cifrata**: chat, preferenze, decisioni di progetto e indice dei tuoi file restano sul tuo disco.
- **Backup cifrati**: esporti/importi una sessione in un file cifrato (salt casuale per ogni export).
- **RAG locale**: cerca nei tuoi file senza mandarli fuori (solo i frammenti approvati possono uscire).
- **Multi-fornitore + locale**: OpenRouter, OpenAI, Anthropic o Ollama sul tuo computer; puoi lavorare al 100% offline.

g) Memoria di progetto e lavoro strutturato

- **Supermemory**: fatti e preferenze salvati in memoria che il modello ritrova tra le sessioni.
- **Decision log (ADR)**: registra le decisioni con la loro motivazione, così l'AI non le rimette in discussione.
- **Conversation Git**: le conversazioni si ramificano come in git (branch, merge, diff, grafo, blame, provenienza).
- **Context budgeter**: tieni sotto controllo quanto contesto stai inviando, turno per turno.

h) Estendibilità in sicurezza

- **Strumenti veri** (function calling): leggere, scrivere, modificare file, applicare patch, cercare, eseguire comandi — con differenze mostrate prima/dopo.

- **MCP con protezioni**: server solo quelli che autorizzi, ambiente ripulito, processo isolato.
- **Regole locali** (AGENTS.md), comandi personalizzati in file .md, temi e scorciatoie configurabili.
- **Due interfacce**: TUI da terminale e web UI locale (loopback + token), stesso motore, stessa cifratura.

3. Confronto rapido

Aspetto	Coding agent tipici	Enclave
Cronologia chat	Spesso in chiaro	Cifrata (SQLCipher/AES-256)
Chiavi API	File leggibile	Env o file 0600
Telemetria	Spesso presente	Nessuna
Dati che escono	Tutto ciò che scrivi	Guard + policy + redazioni
Esecuzione comandi	Con i tuoi permessi	Sandbox + approvazione
Prompt injection	Spesso non gestito	Dato non fidato + canary
Prova degli invii	No	Ledger cifrato con catena di hash
Modello locale/offline	Raro	Ollama + air-gap
Licenza	Variabile	MIT (aperta)

4. In una riga

Gli altri agent ti danno **potenza**. Enclave ti dà potenza **e** il controllo: sai cosa esce, puoi provarlo, e se vuoi non esce niente.

Nota onesta: cosa Enclave non è

Enclave non è un ambiente integrato nel tuo editor con completamento automatico mentre digiti, né punta alla massima "comodità a tutti i costi". È uno strumento da terminale (più una web UI locale) pensato per chi mette davanti la **riservatezza dei dati** senza rinunciare agli strumenti di un coding agent moderno. La privacy qui non è una casella da spuntare: è il motivo per cui esiste.

Enclave 0.1.0 · licenza MIT · autore Mauro · documento generato localmente, nessun dato inviato.